Rapport de campagne — CyberAar / AarMe

Chercheur : William_root · `@william_root` · **ID** : `AMR-Y6ABV5` · vianney24lechancelier@gmail.com
Date : 22 octobre 2026 · **Programme** : CyberAar / AarMe (bug bounty)
Périmètre testé : `aarme.cyberaar.io` (Critique) · `cyberaar.io/api/*` (Standard) · `cyberaar.io` + `www.cyberaar.io` (Standard)
Résultat : **0 vulnérabilité exploitable confirmée** · 20+ contrôles vérifiés conformes · 1 observation de robustesse (non soumise comme vulnérabilité)

1. Résumé exécutif

La campagne a couvert la surface publique et la surface authentifiée des trois actifs du programme : cartographie des endpoints, formulaires publics, comptes, sessions, double authentification, codes de secours, upload, profils publics, API de données et soumission de rapport. **Aucune vulnérabilité exploitable n'a été confirmée.**

Les défenses mesurées sont solides et cohérentes : validation stricte des entrées, sessions liées au facteur de double authentification, cloisonnement des données sensibles derrière l'identité validée (KYC), ré-encodage des images, CSP stricte, absence de SSRF, réponses uniformes contre l'énumération de comptes. Une seule anomalie de robustesse a été observée (acceptation de caractères CR/LF dans les formulaires), mais **son exploitation n'a pas pu être démontrée** : elle est donc documentée comme recommandation de durcissement, pas comme vulnérabilité.

Aucune donnée réelle n'a été modifiée ou supprimée. Aucun test de déni de service, aucune ingénierie sociale, aucun scan automatisé non accompagné de PoC. Les tests ont utilisé des comptes créés pour la campagne, avec des adresses appartenant au chercheur, et le plafond de débit de la plateforme a été respecté (une requête par test, espacée).

2. Périmètre et méthode

Actif	Classe	Surface explorée
`aarme.cyberaar.io`	Critique (58,3/100)	Pages publiques, compte, sessions, 2FA, codes de secours, profil, upload d'avatar, API publique du hacker, API de soumission (lecture du script client)
`cyberaar.io/api/*`	Standard (28,3/100)	`/api/contact`, `/api/apply` (formulaires publics)
`cyberaar.io` + `www`	Standard (11,7/100)	En-têtes, CSP, HSTS, `security.txt`, pages de divulgation

Méthode : cartographie manuelle et scripts ciblés (53 sondes), observation des réponses et des latences, test des contrôles d'accès avec deux comptes de test (dont un sans 2FA), upload de fichiers polyglottes, écouteur hors bande (OOB) pour détecter un rappel serveur, et lecture du script client de soumission pour comprendre les prérequis. Chaque affirmation de ce rapport renvoie à une mesure reproductible (scripts et journaux conservés dans le dossier de campagne).

3. Contrôles vérifiés conformes

Contrôle	Mesure
CSRF sur les POST publics	`Origin`/`Referer` same-origin exigé ; sans → `403 forbidden`.
Adresses jetables	Refusées (`disposable_email`).
Énumération de comptes (login)	Message unique `invalid_credentials`, que le compte existe ou non ; pas d'oracle de timing (257-304 ms vs 283-284 ms).
Réinitialisation de mot de passe	Réponse unique `{"success":true}` sur 5 adresses (existantes ou non) → pas d'énumération.
Confirmation d'adresse	`{"error":"invalid_token"}` uniforme, même avec le mot de passe correct → la preuve de propriété est exigée.
Double authentification	Le code TOTP n'est accepté que lié à la session de l'étape précédente (un `totp` seul est ignoré) ; cookie `Secure; HttpOnly; SameSite=Lax`.
Codes de secours	Exigent le mot de passe courant **et** un TOTP vivant ; avec le vrai mot de passe + un faux TOTP → `invalid_code`, aucun code divulgué.
Cloisonnement KYC	`/account/report/payout` → `403 kyc_required` ; `/api/aarme/attachment` → `403 identity_required`.
Mass assignment	Champs inconnus ignorés (`nothing_to_update`) sur le profil ; `invalid_input` sur les formulaires ; les champs de privilège sont rejetés.
Validation des champs publics	`invalid_name` / `invalid_country` : aucune balise HTML injectable dans le profil public (3 payloads testés).
Upload d'avatar	Type sniffé (`image/png,jpeg,webp`) ; PNG 1×1 refusé, vrai 400×400 accepté ; polyglotte PNG+HTML acceptée mais **ré-encodée** (payload supprimé) ; nom remplacé par un aléatoire `.png` ; servi `image/png` + `nosniff` + `CSP: default-src 'none'; sandbox`.
SSRF	Le champ `profile` (seule URL acceptée) n'est jamais récupéré par le serveur, ni à l'inscription ni au rendu du profil (0 requête sortante observée sur l'écouteur OOB).
XSS stocké public	CSP stricte sans `'unsafe-inline'` en `script-src` ; les champs publics rejettent le HTML ; aucun gestionnaire d'événement en attribut ne s'exécute.
En-têtes de sécurité	CSP stricte, HSTS `preload`, `X-Frame-Options: DENY`, `nosniff`, `frame-ancestors 'none'`, `object-src 'none'`, `base-uri 'self'`.
API publique du profil	`GET /api/aarme/hacker/<handle>` n'expose que `avatar` (booléen), `country`, `game` — ni email, ni KYC, ni sanctions, ni URL de profil ; pseudo inexistant → `404 not_found` uniforme.
Surface API	11 endpoints sur AarMe (dont 3 publics), 2 sur l'API formulaires, 30 endpoints de compte ; verbes corrects (`PATCH` profil, `DELETE` en-tête/avatar) ; pas de route d'administration exposée.
Plafond de débit	Plafond d'entrée 60/min (300/min avec l'en-tête chercheur) + plafond dédié aux formulaires, à fenêtre longue → `429 rate_limited` mesuré.
Pot de miel	Champ `hp` absorbé en silence (`200 success` sans création).

4. Observation de robustesse : caractères CR/LF dans les formulaires

Ce qui est mesuré : les champs `name`, `subject` et `message` de `POST /api/contact` acceptent des caractères `\r\n` et renvoient `200 {"success":true}` ; l'e-mail de notification part (latence 2,7-4,8 s). Le champ `email`, lui, est validé (`400 invalid_email`).

Ce qui n'est pas démontré : l'accusé de réception reçu par l'expéditeur est un **modèle fixe** — il ne reprend pas le nom (« Bonjour, » sans le nom), donc il ne permet pas d'observer une injection. Aucune copie `Bcc` n'est arrivée dans la boîte de test. L'e-mail de notification interne à l'équipe n'est pas observable depuis l'extérieur. **L'injection n'est donc pas démontrable** et n'est pas soumise comme vulnérabilité.

Recommandation : supprimer systématiquement les caractères CR/LF de tous les champs fournis par l'utilisateur avant toute construction de message :

```
const clean = (v) => String(v ?? '').replace(/[\r\n]+/g, ' ').trim();
```

Si l'équipe constate dans sa propre boîte un en-tête injecté (ligne `Bcc:`, `Content-Type:`, `Subject:` replié) ou des lignes arbitraires dans le corps de la notification, l'observation devient une injection CRLF (CWE-93) et peut être re-qualifiée.

5. Observations diverses

Observation	Lecture
`admin.aarme.cyberaar.io` résout vers `10.9.0.10` (RFC1918)	Divulgation d'adressage interne de faible portée ; l'hôte est injoignable depuis Internet et aucun SSRF ne permet de l'atteindre (le serveur ne récupère aucune URL). Pas d'exploitation.
`X-AarMe-Researcher` : `eligible:false` pour un compte non vérifié	Conforme : l'en-tête est réservé aux comptes à identité validée + 2FA ; il porte le trafic de 60 à 300/min. Ne pas le forger (réponse `invalid_researcher_header` + signalement SOC).
Plafond des formulaires	Le plafond est bien appliqué (`429 rate_limited`) ; il a limité la campagne à une requête par test, espacée. C'est un contrôle, pas un défaut.
Soumission de rapport	Exige une identité validée (KYC) : le bouton « Soumettre » est masqué et l'upload de la pièce jointe renvoie `identity_required`. Contrainte du programme, pas une vulnérabilité.

6. Pistes testées et écartées

Piste	Motif d'exclusion
SSRF via l'URL de profil	Aucune récupération d'URL par le serveur (0 requête OOB).
XSS stocké dans le profil public	Validation serveur du nom et du pays + CSP sans `'unsafe-inline'`.
XSS via l'avatar (polyglotte image/HTML)	Contenu ré-encodé, renommé, servi `image/png` avec `nosniff` et CSP `sandbox`.
Énumération de comptes	Messages et latences uniformes sur le login et le reset.
Fuite de données par l'API publique	Aucun champ sensible exposé (avatar, pays, jeu).

IDOR sur les objets de compte	Les endpoints de données sensibles sont protégés par session et/ou identité validée ; les identifiants publics ne donnent accès à rien.
Contournement de la 2FA	Le TOTP est lié à la session ; les codes de secours exigent le mot de passe courant + un TOTP vivant.
Injection CRLF → Bcc	Charge acceptée mais aucune copie Bcc reçue ; accusé de réception à template fixe → non démontré (voir §4).

7. Limites

- `admin.aarme.cyberaar.io` résout vers une adresse privée : le rendu de l'interface de triage n'a pas pu être observé.
- La soumission de rapport et l'upload de pièce jointe exigent une identité validée (KYC) : le flux complet de soumission n'a pas été exécuté.
- L'e-mail de notification interne à l'équipe n'est pas observable depuis l'extérieur ; l'observation CRLF reste donc non qualifiée.
- Aucune donnée réelle n'a été consultée, modifiée ou supprimée ; aucun test de disponibilité n'a été réalisé.

8. Conclusion

La plateforme CyberAar / AarMe présente un niveau de maturité élevé sur la surface testée : validation stricte, sessions liées à la 2FA, cloisonnement KYC, upload ré-encodé et sandboxé, CSP stricte, absence de SSRF et réponses uniformes contre l'énumération. **Aucune vulnérabilité exploitable n'a été confirmée.** La seule anomalie observée (acceptation de CR/LF dans les formulaires) est une recommandation de durcissement : elle n'a pas d'impact démontré et n'est pas soumise comme vulnérabilité.

Les scripts, journaux et captures de la campagne sont conservés dans le dossier de campagne ; chaque ligne de ce rapport renvoie à une mesure reproductible.